

A3-PS002-TC320

Purpose-Based Consent Recording & Withdrawal Prototype

Anupam Raj
anupam.raj.csbs28@heritageit.edu.in
AIORI Hackathon 3
October 11, 2026

Problem Description

Key issues

• Consent is often recorded in a database but not enforced in downstream data flows, so processing can continue after a user withdraws.
• Consent is frequently bundled rather than tied to explicit, itemized purposes.
• Records often do not show which notice version the user agreed to, which weakens the evidence trail.
• Audit trails are hard to export and verify independently, and unauthorised access requests are rarely tested systematically.

Regulations such as India's DPDP Act and the GDPR expect personal data to be used only for specific, itemized purposes and corresponding processing to stop when consent is withdrawn. In practice, consent is logged but not enforced where data is actually shared, thus there is the requirement of a application which manages the a consent-management workflow, ensuring enhanced privacy and safety

Background

Understanding the problem

• Data protection laws, including the GDPR (Articles 6 and 7) and India's DPDP Act, 2023, require consent to be specific to a purpose, informed by a notice, and withdrawable [1], [2].

• The GDPR states that withdrawing consent must be as easy as giving it, and the DPDP Act gives the data principal the right to withdraw consent.

• Many systems store consent as a flag or a row in a table, but downstream services such as analytics, marketing and partner sharing never consult it at request time.

• A consent record is only useful as evidence if it shows who consented, for which purpose, to which version of the notice, and when. It must also show that later access was allowed or denied according to that state.

• When a notice changes, earlier consent may no longer match the text the user saw, so the system needs a way to detect this and treat the consent as stale

Literature & RFC Review

Exisiting Infrastructure & Proposals

• **GDPR (Regulation 2016/679), Arts. 6-7 [1]** : consent must be specific and demonstrable, and withdrawal must be as easy as giving consent.
• **DPDP Act, 2023 (India) [2]** : consent must be free, specific and informed, linked to a notice, and the data principal may withdraw it at any time.
• **ISO/IEC 29184:2020 [3]** : guidance on online privacy notices and consent, including notice content and recording consent decisions.
• **Kantara Consent Receipt Specification v1.1 [4]** : a model for a machine-readable record of what was consented to, by whom, for which purpose and under which notice. It informs the audit record fields.
• **W3C Data Privacy Vocabulary (DPV) [5]** : a vocabulary for describing purposes and processing, which informs the purpose naming.

Proposed Solution

Overview

The proposed prototype is a consent-management workflow for a synthetic fitness app, FitTrack Lite, built with Python (FastAPI) and SQLite, with a simple web consent dashboard.

It consists of four parts:

• **Consent dashboard** : a synthetic user views the current notice version and grants or withdraws consent for each purpose.

• **Consent service and store** : every grant or withdrawal is saved as an append-only event with user ID, purpose, notice version hash (SHA-256), action and timestamp. The current state is derived from the latest event.

• **Mock data-sharing API** : a downstream consumer requests user data for a stated purpose. The API checks live consent state and notice version on every request and returns 200 (allowed) or 403 (denied) with a reason code.

• **Audit log and export** : consent events and every allow/deny decision are recorded in a hash-chained log (each entry includes the previous entry's hash) and can be exported as JSON/CSV.

Optimization Proposed

Behaviours to be demonstrated

- **Grant**
- **Withdrawal**
- **Notice change :** consent given under an older notice hash is treated as stale and denied until the user re-consents
- **Unauthorised requests :** denied when there is no consent, wrong purpose, wrong user, unknown user or unknown purpose.

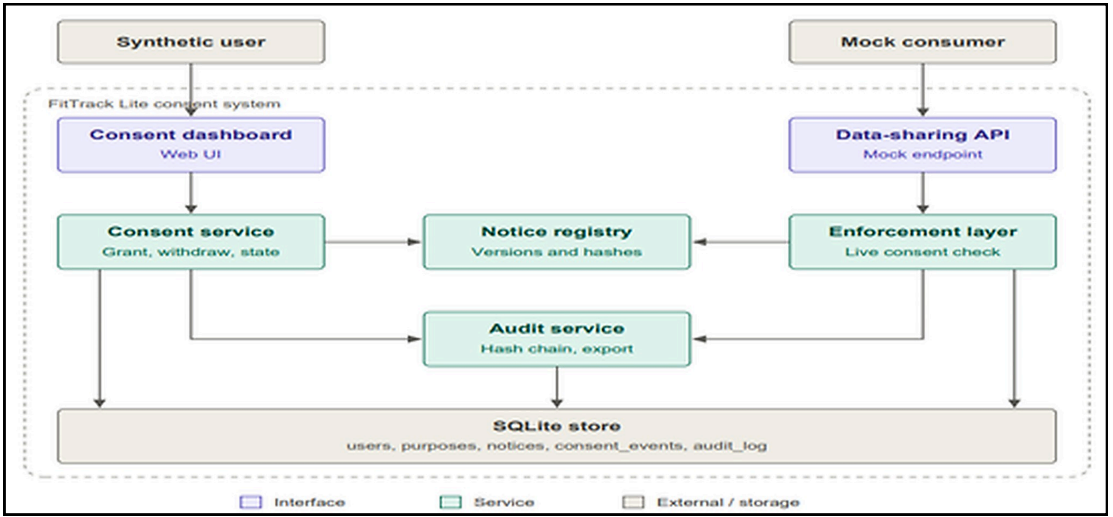
Aspect	Before (typical approach)	After (this prototype)
Consent storage	A single mutable flag per user	Append-only events (purpose, notice hash, action, timestamp)
Enforcement	Consent stored but not checked downstream	Mock API checks live consent on every request
Withdrawal	Takes effect after a batch job, or never	Takes effect immediately; the next request is denied
Notice changes	Old consent silently carries over	Consent under an older notice hash is denied until re-consent
Purpose handling	One bundled consent	Three separate, itemized purposes
Unauthorised requests	Often served, or fail without a clear reason	Denied with 403 and a reason code (no consent, withdrawn, stale notice, unknown user/purpose)
Evidence	Hard to reconstruct what happened	Hash-chained audit log, exportable as JSON/CSV
Verification	Ad hoc manual checks	12+ automated lifecycle and enforcement tests

Table 1 : Comparative Study

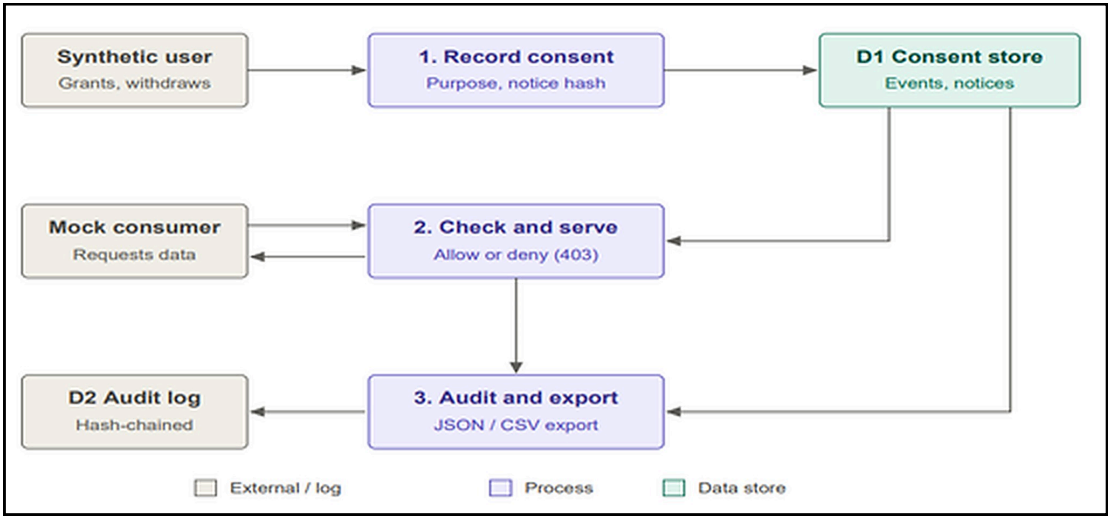
Item	Definition
Service	FitTrack Lite (fictional fitness app)
Users	Synthetic users only (for example user_01 to user_05); no real personal data
Purpose P1	Service Analytics - usage statistics for improving the app
Purpose P2	Marketing Communications - promotional emails and offers
Purpose P3	Partner Data Sharing - activity data shared with a mock wellness partner
Notice versions	v1 and v2, each stored with its SHA-256 hash

Table 2 : Prototype description

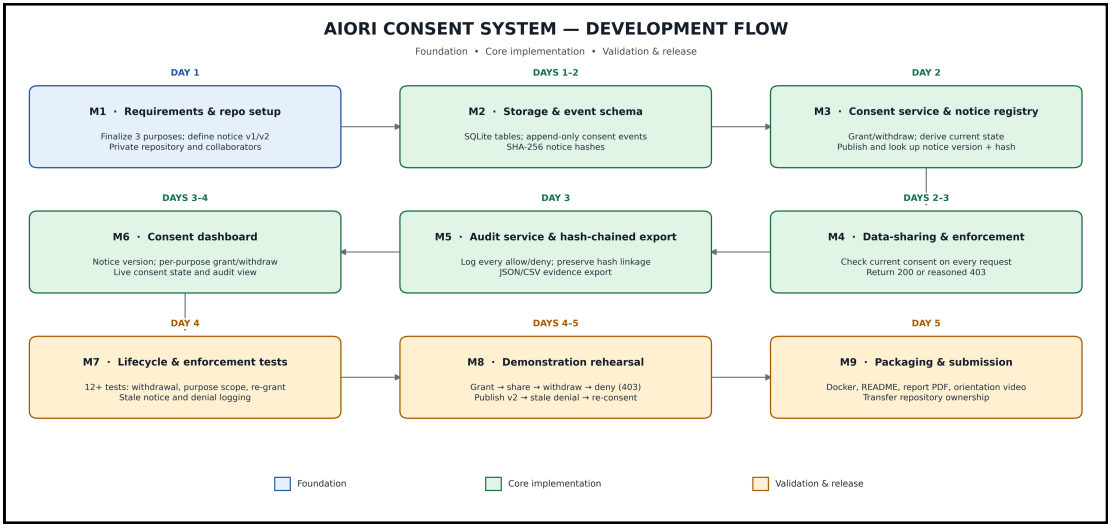
Solution Architecture & Design



Data Flow Diagram



Deployment Timeline



Bibliography I

[1] European Parliament and Council. "Regulation (EU) 2016/679 (General Data Protection Regulation)". In: Official Journal of the European Union L119 (2016), pp. 1-88.

[2] Government of India. "The Digital Personal Data Protection Act, 2023 (Act No. 22 of 2023)". In: The Gazette of India (Aug. 2023).

[3] ISO/IEC. ISO/IEC 29184:2020 - Information technology - Online privacy notices and consent. International Organization for Standardization, 2020.

[4] Kantara Initiative. Consent Receipt Specification, Version 1.1. 2018.

[5] W3C Data Privacy Vocabularies and Controls Community Group. Data Privacy Vocabulary (DPV). World Wide Web Consortium.

[6] D. Eastlake 3rd and T. Hansen. US Secure Hash Algorithms (SHA and SHA-based HMAC and HKDF). RFC 6234. IETF, May 2011.

[7] A. Rundgren, B. Jordan, and S. Erdtman. JSON Canonicalization Scheme (JCS). RFC 8785. IETF, June 2020.

[8] R. Fielding, M. Nottingham, and J. Reschke (eds.). HTTP Semantics. RFC 9110. IETF, June 2022.

[9] M. Nottingham, E. Wilde, and S. Dalal. Problem Details for HTTP APIs. RFC 9457. IETF, July 2023.